Remaining Functions & Validation Gaps

A prioritized list of work not yet complete, checked against all 21 system sections, 21 workflows, 30 security measures, and database rules in the supplied master-plan PDF.

SOURCE	HOW TO READ	SCOPE
BackyardMech Complete System Master Plan 16 pages	**Only incomplete, partial, or deployment/design items are listed. Completed items are excluded unless a related gap remains.**	**Current source code, SQL schema, project workflow/security notes, and test coverage descriptions.**

Executive Summary

The workshop application already has a substantial set of staff workflows, so this report does not repeat the functions that are already implemented. The remaining gaps are concentrated in customer-facing services, production-grade security and operations, database-level invariants, and a few unfinished exception paths. The master plan itself says it is a blueprint and that some status/design rules are pending; pending policy decisions are listed separately from code that is definitely absent.

Priority key

Label	Meaning
High	Affects approval/security integrity, data consistency, or a core customer/workshop flow.
Medium	Important completion, reporting, lifecycle, or durable validation gap.
Production / pending decision	Must be configured or decided before production; may not require a new UI feature.

Top gaps to address first

- Customer approval links are not delivered through email/SMS, and stored tokens are not hashed.
- Initial inspection lacks structured measurement data and duplicate/re-inspection controls; media writes need safer lifecycle handling.
- Some critical rules live only in application code; unique/check constraints and status rules are incomplete in SQL.
- Full Identity migration and production operations (backups, least privilege, monitoring, incident response) are not complete.
- A public customer portal/catalog/booking flow is missing; e-commerce checkout is not required by the master plan.

Part A | Master Plan Sections 1-7

Gaps by the master plan's 21 main sections. 'No additional gap found' means the reviewed core requirement appears implemented; it is not a certification of every edge case.

Section / priority	Remaining function or validation gap
1. Architecture & system flow **HIGH**	No separate customer portal flow or outbound notification service is present. The app remains staff-focused, apart from the token approval page. Full Identity user/role-store migration is not done.
2. Employee accounts / roles **PRODUCTION**	Migrate existing custom Users/AppRole/session architecture to ASP.NET Core Identity (UserManager/SignInManager/stores) if required by the blueprint. Preserve the new per-user permission overrides during migration.
3. Availability / exceptions **PRODUCTION**	Core scheduling checks exist. Before multi-instance deployment, verify shared session/Data Protection keys and distributed edge rate limiting; application lock behavior should be load-tested in the actual SQL deployment.
4. Garage master data **MEDIUM**	No complete supplier purchase-order/delivery verification process. Existing 'Received' stock movement is not a supplier-receipt record tied to a delivery/reference.
5. Product listing **HIGH**	No customer-facing catalog browse/request-service workflow. The staff CRUD exists. Do not add cart/payment checkout unless separately required; the plan explicitly says e-commerce is unspecified.
6. Customer registration **MEDIUM**	No server-side likely-duplicate customer warning/rejection was found at create time. Customer records are staff-managed; customer sign-in/self-service is absent.
7. Vehicle ownership **MEDIUM**	Authority is verified through staff confirmation/reason rather than an external proof workflow. This is a residual business control, not an external verification requirement in the SQL design.

Part A | Master Plan Sections 8-14

Section / priority	Remaining function or validation gap
8. Appointment booking **MEDIUM**	Appointment create/edit/cancel and walk-in are present, but appointment confirmation/reminders are not actually sent. The notification toggles in settings are preferences/UI, not a connected delivery service.
9. Check-in / queue / bay **MEDIUM**	No single finalized status-transition map. Current flows use operational labels that do not exactly match the PDF's proposed states; define allowed next states and terminal/reopen rules across queue, appointment and work order.
10. Vehicle inspection **HIGH**	No structured initial inspection measurement/checklist rows in the 42-table schema. Duplicate initial inspections/reinspection reason are not governed. Photo file save and DB metadata are not atomic; malware scanning and cleanup/retention are absent.
11. Estimate revisions **HIGH**	Add a database unique constraint for (EstimateId, RevisionNumber). Current application flow serializes revision writes, but SQL does not independently enforce this invariant.
12. Customer approval **HIGH**	No email/SMS send, delivery status, reminder, or customer recipient verification. Token is stored as raw GUID instead of hash. Add explicit revoke/resend and a complete Changes Requested -> revised estimate -> new link flow.
13. Work orders / assignments **MEDIUM**	Confirm one canonical state-transition policy and exception/override policy for assignments and rescheduling. App checks protect tested paths; status vocabulary remains unsettled in the blueprint.
14. Service time tracking **MEDIUM**	Add durable DB checks for segment end >= start and valid date/range. Current app controls timers and prevents a mechanic from keeping multiple open timers, but SQL does not enforce segment chronology/overlap.

Part A | Master Plan Sections 15-21

Section / priority	Remaining function or validation gap
15. Parts / supplier operations **MEDIUM**	Add supplier delivery/receipt verification and reference linkage if required by Flow 14. SQL has core FKs/checks, but full audit-ledger invariants and source documents are not represented.
16. Tool checkout / maintenance **MEDIUM**	No audited resolution workflow for a tool marked Missing (recovered, retired, written off). Calibration work type and due-date requirements need a fixed allowed list/policy. Do not add an override that permits unsafe checkout unless shop policy explicitly requires it.
17. Independent QC **MEDIUM**	No major core function gap found in inspected flow: six checks, independent mechanic separation, fail/rework and pass-to-billing exist. Remaining validation: approve checklist content and test identity matching for legacy/name-only assignments.
18. Invoice / tax **MEDIUM**	Settle canonical invoice states: code uses Issued/Partially Paid/Voided while the PDF suggests Open/Paid/Void/Credited (some are proposed, not finalized). Keep state rules consistent across UI, reports, SQL and tests.
19. Payments / adjustments **MEDIUM**	Refund/reversal and reconciliation policies remain pending. App blocks overpayment and supports payment void, but there is no dedicated refund lifecycle. No gateway is required; never store raw card details.
20. Reports / dashboards **MEDIUM**	Add plan-listed report views not evident among current seven: unpaid-invoice aging, QC performance, queue performance, tax summaries, and tool utilization (distinct from tool-loss reporting). Harden CSV against whitespace/control prefixes and consider separate export permission.
21. Audit / incident response **PRODUCTION**	No tamper-evident/append-only audit archive, alerting/monitoring, investigation/recovery runbook, or evidence-preservation process. Existing audit events alone do not provide incident response.

Part B | Database & Validation Gaps

SQL already includes many business foreign keys, nonnegative CHECK constraints, and unique indexes. The gaps below are specific; it would be inaccurate to say that the schema has no constraints.

Priority	Missing / incomplete database rule	What to enforce
HIGH	ProductListing.PartOrService CHECK permits both PartId and ServiceId to be NULL. It does not ensure ListingType matches the populated FK.	Require exactly one non-null source, then require that source to match ListingType. Add tests for Part, Service, neither, and both.
HIGH	No unique (EstimateId, RevisionNumber) constraint.	Unique index/constraint so a concurrent or alternate write path cannot duplicate revision numbers.
MEDIUM	No unique (RolePermission.RoleId, PermissionId) constraint identified.	Add composite unique constraint; handle existing duplicates before applying.
MEDIUM	Payment.Amount database CHECK permits zero (>= 0), although a payment should be positive.	Use > 0 for posted payments; retain zero only if voiding design requires it, ideally represent void state separately.
MEDIUM	Several allowed business date/status rules exist only in controller/service logic.	Add checks for appointment and availability ranges, ServiceTimeSegment chronology, and allowed enum/state values where compatible.
MEDIUM	Many actor IDs and user/role relations are snapshots or strings, and not every actor relation has a DB FK.	Review each reference; add FK only where IDs are stable and compatibility permits. Keep name snapshots for historical display.
MEDIUM	Product line quantity/source, category references and some effective-date invariants rely on application validation.	Align SQL CHECK/FK/unique indexes with server rules; don't depend on a Razor dropdown as validation.

Application validation gaps

- Customer creation: no server-side likely-duplicate check. Define match signals and show a safe warning before duplicate creation.
- Inspection: block duplicate initial inspection or require reason/version linkage for reinspection; stage files and roll back/clean up on save failure.
- Uploads: scanning for malicious files is not present; set server request-size limits and define retention/backup/deletion for media.
- Status transitions: reject invalid transitions centrally, including stale concurrent requests; don't let an unknown status reach billing or dispatch.
- Calibration: restrict maintenance type to known values and require calibration due date/interval when type is Calibration.
- Data privacy: define retention for each sensitive record class, not only employees/customers/vehicles/parts/listings/tools; document the Philippine DPA review separately.

Part C | Security Gaps from the 30-Item Checklist

The master plan marks security measures as requirements/recommendations. This section lists only those not fully completed or requiring production configuration.

PDF item(s)	Gap still remaining
1. Secure authentication	Full ASP.NET Core Identity stores/UserManager/SignInManager migration remains. Existing password/MFA/session controls are a partial substitute, not completion of this item.
3. Login abuse defense	Failed-attempt lockout and rate limiting exist; suspicious-login monitoring/alerting is absent. Current limits/session store are single-instance unless deployed with shared services.
4. Record-level authorization	Staff role/module authorization exists. Customer portal isolation is not implemented/testable because there is no authenticated customer portal. Public approval URL is bearer-token access.
7. Content Security Policy	Razor output encoding is available, but no explicit Content-Security-Policy header/policy was found.
9-10. Input validation / secure uploads	Many field/range/business checks exist, but listed gaps remain. Upload malware scanning is absent; request size and image lifecycle need production hardening.
11. Private media	Staff photo action is permission protected. Complete private-storage configuration, backup, retention, cleanup, and access monitoring are not delivered as a production policy.
12. Approval tokens	Expiry, replay and current-revision checks exist. Raw GUID stored rather than hash; no communication delivery record, customer verification, reminder or explicit management lifecycle.
13-14. Encryption / secrets	Database/storage encryption and protected backup settings depend on deployment. Key-ring persistence/protection and external secret provisioning need setup and verification.
16. Log integrity	Audit rows are in ordinary database tables; no append-only/tamper-evident store, restricted retention archive or integrity alarm.
18-20. DB privilege / backup / monitoring	No production least-privilege SQL account script, automated encrypted backups/restore drills, central monitoring or incident alert/response workflow identified.
22-24. Privacy / dependencies / tests	Full privacy/retention legal review and dependency scanning/patch automation are not documented. Existing smoke tests are useful regressions, not OWASP ASVS or penetration-test evidence.
25. Export security	Current CSV escaping prefixes values beginning with =,+,-,@. Leading whitespace/control characters can bypass simple first-character checks; financial export has no separate permission from report view.
26. Financial integrity	Core invoice/payment/adjustment safeguards exist. Refund/reversal/reconciliation policy remains pending; DB positive-payment constraint should be stricter.
29-30. Customer isolation / incident readiness	No customer portal authorization to prevent cross-customer IDOR; no incident contacts, containment, recovery, or evidence-preservation runbook.

Part D | Recommended Completion Order

Ordered to close the largest integrity and production risks first.

Order	Deliverable
1. Database integrity	Fix ProductListing source CHECK; add unique revision and RolePermission pairs; tighten positive payment/date/time checks; plan compatibility migration and duplicate cleanup.
2. Inspection & customer approval	Add inspection repeat/version rules and structured measurements if required; secure media lifecycle; hash tokens; implement email/SMS, resend/revoke, delivery log and Changes Requested revision loop.
3. Customer-facing scope	Decide and build customer portal/catalog/appointment requests; add record-level customer authorization. Do not build e-commerce checkout unless approved separately.
4. State policies & exceptions	Publish one state-transition map; finish missing-tool disposition, calibration policy, payment refunds/reconciliation and override policy.
5. Reports & export	Add missing operational/tax/aging reports; strengthen CSV formula defense; add export-specific permission and scope audit.
6. Production hardening	Identity migration plan; distributed session/rate limit and Data Protection keys; DB least privilege; encrypted backup + restore drills; monitoring, alerting and incident runbooks; security/dependency testing.

Master-plan workflows with no major core function gap found

This list is intentionally short and does not mean production sign-off: employee availability checks; core vehicle ownership/odometer history; approved work-order conversion; service timers; independent QC; invoice numbering and core billing; core parts reservation/install/waste ledger. These areas still depend on the schema/status and production hardening gaps above.

Basis and limitations

Source: docs/BackyardMech_Complete_System_Master_Plan.pdf, all 16 pages (21 system sections, 21 workflows, 30 security requirements, 42-table inventory, database/status rules and roadmap). Cross-checked against current Controllers, Models, Services, Database/BackyardMech_BusinessSchema.sql, project docs and smoke-test descriptions. This is a source review, not a complete rerun of all test suites, penetration test, legal review, or production deployment audit. The PDF labels itself a blueprint and says it is not evidence of implementation; proposed statuses and pending design decisions are treated as decisions to finish, not bugs by themselves.